AI 與資安工作的協作與替代性評估

—— 以 **B2B** 網站開發生命週期為例

教師：查士朝 教授
學生：**M11509904** 張健志

前言：**AI** 協作紀實與品質控管評估

- 產出過程記錄：本報告採用人機協作模式撰寫。由人類定義 B2B 網站系統開發生命週期（SDLC）與資安框架，並利用大型語言模型（LLM）進行各階段細節展開與初稿生成。
- 品質控管機制：結合軟體工程知識體系（SWEBOK）與專案管理實務，對 AI 生成的內容進行邏輯審查與事實查核。特別針對企業級架構的限制（如資料庫同步、API Gateway 路由安全）進行內容修剪，確保產出符合實務標準。
- 人機協作評估：AI 展現了強大的資訊彙整與樣板生成能力，大幅縮短了文件撰寫與基礎防護策略的發想時間。然而，涉及核心商業邏輯的風險評估與最終資安決策，仍需依賴人類的專業經驗與管理直覺進行最終定奪。

1. B2B 網站開發之 AI 協作與實作說明

在企業 B2B 採購或訂單管理系統的開發過程中，導入 AI 工具（如 Gemini Code Assist、GitHub Copilot 或其他 AI 代理）能顯著提升各階段的產出效率：

- **1-1.** 需求分析與 **AI** 協作：利用 AI 總結利害關係人會議記錄，自動梳理出跨部門的業務邏輯，並輔助生成標準化的使用者故事（User Story）與系統需求規格初稿。
- **1-2.** 規格分析與 **AI** 協作：在架構設計階段，AI 協助快速生成 API 規格文件（如 OpenAPI/Swagger 格式）、關聯式資料庫（如 MSSQL）的 Schema 設計建議，以及 UML 系統循序圖與架構圖草稿。
- **1-3.** 系統開發與 **AI** 協作：開發人員透過 AI 程式輔助工具進行 .NET Core 後端 API 與 Angular 前端元件的撰寫。AI 可即時提供樣板程式碼、演算法建議，並自動補齊程式碼註解，加速核心模組的建置。
- **1-4.** 系統測試與 **AI** 協作：AI 根據開發完成的 API 自動生成單元測試（Unit Test）腳本與測試假資料（Mock Data），並輔助開發邊界條件（Edge Cases）的自動化測試案例。
- **1-5.** 系統驗收與 **AI** 協作：將需求規格與完成品狀態輸入 AI，協助比對功能落差，並草擬使用者驗收測試（UAT）計畫與檢核表，加速業務端驗收流程。
- **1-6.** 系統上線與 **AI** 協作：AI 輔助檢視 Docker 容器化設定、CI/CD 管線（Pipeline）腳本，優化自動化部署流程，並檢查組態檔是否有遺漏設定。
- **1-7.** 系統維運與 **AI** 協作：導入 AI 進行自動化系統日誌（Log）分析，快速從海量數據中梳理出錯誤根因（Root Cause），並協助撰寫技術維護文件與版本更新說明。

2. 開發生命週期各階段之對應資安工作

針對上述 B2B 網站的開發與維運，資安工作必須「左移（Shift-Left）」並貫穿全局：

- **2-1.** 需求分析的資安工作：執行威脅建模（**Threat Modeling**），評估 B2B 交易中訂單、價格與客戶機敏資料的保護級別與合規需求。
- **2-2.** 規格分析的資安工作：設計安全架構，制定身分認證與授權機制（如 RBAC、OAuth2.0）、API 閘道器防護規則，以及資料庫靜態加密與傳輸加密（TLS）規範。
- **2-3.** 系統開發的資安工作：落實安全程式碼開發（**Secure Coding**）。執行靜態應用程式安全測試（SAST），防範 SQL Injection、XSS 及 CSRF 等常見程式碼漏洞。
- **2-4.** 系統測試的資安工作：執行動態應用程式安全測試（DAST）與弱點掃描。針對 B2B 核

心交易模組進行滲透測試，確保異常操作不會導致權限越權或資料外洩。

- **2-5.** 系統驗收的資安工作：確立並審查資安驗收基準（**Security Acceptance Criteria**），確保系統符合企業內控規範與外部法規（如個資法或 ISO 27001 要求）。
- **2-6.** 系統上線的資安工作：執行正式環境的組態安全檢核。確保防火牆規則正確開啟、密碼與金鑰以安全的憑證庫管理（避免硬編碼於部署檔中），並移除所有測試用後門與帳號。
- **2-7.** 系統維運的資安工作：建置持續性安全監控（**SIEM**）。定期執行漏洞修補與系統更新（Patch Management），並隨時準備啟動資安事件通報與緊急應變機制（Incident Response）。

3. AI 與資安工作的協作與替代性評估

綜合上述 B2B 網站開發與資安實務，AI 在資安領域的介入將帶來結構性的轉變。其協作價值與替代性評估如下：

A. 高度協作性（AI 作為資安擴增引擎）

AI 擅長處理「速度」與「廣度」的挑戰。在系統開發（SAST）與測試（DAST）階段，AI 能以極高的效率掃描龐大的程式碼庫，即時標記潛在漏洞並提供修補建議。在系統維運階段，AI 語言模型能快速吞吐並關聯海量的系統 Log，精準辨識潛在的 DDoS 前兆、暴力破解或異常的內部資料庫存取行為，充當資安人員的「全天候副駕駛（Co-pilot）」。

B. 替代性評估

- 高替代性（重複性與規則性工作）：
  AI 將大幅替代傳統的初階資安操作。例如：基礎弱點掃描報表的產出、合規性表單的初步填寫、第一線釣魚郵件的過濾，以及已定義規則的防火牆警報判讀。這些工作具備高度規律性，AI 的準確率與不知疲倦的特性將完全勝過人力。
- 低替代性（決策性、脈絡性與架構性工作）：
  AI 難以替代具備深度商業脈絡的決策工作。在規格分析階段的「架構級安全設計」、面對未知威脅的「零日漏洞（Zero-day）防禦策劃」，以及發生資安事件時的「商業損失評估與系統停機決策」，皆需要依賴 IT 管理者的工程經驗與商業直覺。此外，推動跨部門的資安政策與風險溝通，涉及複雜的人性與組織心理，這是 AI 無法涉足的領域。

C. 總結

在未來的軟體開發與 IT 治理中，**AI** 不會完全取代資安人員，但「會使用 **AI** 的資安人員」將取代「不會使用 **AI** 的資安人員」。

AI 將資安工作的核心價值從「防堵漏洞的手工業」提升至「風險管理與架構治理」。資安專業人員的角色將轉型為「AI 資安協作管理師」，其未來的核心能力不在於手動找漏洞，而在於如何向 AI 提出正確的防禦提示（Prompt）、驗證 AI 產出的正確性，並在複雜的商業環境中做出最適切的風險妥協與決策。